Language Models and Agents (CL3.410) | Group Project | Mid-Submission Report

Gate Before You Act

Does Verifying Evidence Make an LLM Security Agent Act More Safely Than Policy Rules Alone?

Team **Simpletons** | 26 October 2026

Varun Modi	**Aayush Pandey**	**Srushti Pekamwar**	**Dhruv Rajput**
2025202040	2025201058	2025201066	2025201094

GitHub repository: https://github.com/varunmodi18/Gate-Before-You-Act (branch `main`, commit `b9ca9e4`)

Status in one paragraph. The software is complete through milestone M7. *GateBench*, our research workbench, ingests the OTRF logs and builds a Sigma/ATT&CK retrieval index. It implements the gate checks C1–C6 and all ten systems (G0–G3, A1–A8), the episode loop with recovery budgets, an MCP transport, the end-to-end investigator, scoring, cluster-bootstrap analysis and a web interface for authoring, annotating, running and reading results. The model is Qwen2.5-7B-Instruct (4-bit AWQ) served by vLLM on an 8 GB laptop GPU. It runs at 1,229 input and 55 output tokens/s, and the proposer produces schema-valid JSON on 80/80 pilot calls. Every experiment runner has completed live runs end to end on hand-made demo cases. 855 unit/integration tests, 19 front-end tests and 47 browser tests pass. **What comes next:** authoring and double annotation of the SOC-Risk case set, the freeze and the research runs, for which every component is now in place. The hypothesis tests (H1, H1-C4, H2) are therefore part of the final submission; the numbers in §5 come from pipeline-validation runs on demo fixtures and are not findings. §7 gives the dated plan to the final submission on 15 November, with the fallback triggers from the proposal and what each would change in our claims.

1. Project Recap

An LLM agent investigates one suspicious Windows host from its Sysmon and Security logs and proposes a response, such as isolating the host or disabling an account. A *gate* checks every state-changing action before it reaches the (mock) tools. A strong gate can enforce written policy alone. We ask whether *also* checking that the cited log evidence supports the specific action improves decisions, with policy, trusted context, model and tools held fixed, and which part of that check helps: deterministic target matching (C3) or the LLM verifier (C4).

Hypotheses (unchanged from the final proposal). H1: on evidence packages that should be rejected (variants E2–E5), the full gate G3 wrongly admits $\geq$15 points fewer actions than the policy-only gate G1. **H1-C4**: on E4–E5, G3 wrongly admits $\geq$10 points fewer than A1 (G3 without the LLM verifier). **H2**: in full episodes, G3's unnecessary-deferral rate is not more than 10 points worse than G1's. Experiment 3 (live end-to-end investigation) is descriptive. Every effect is reported with a 95% cluster-bootstrap interval over source scenarios.

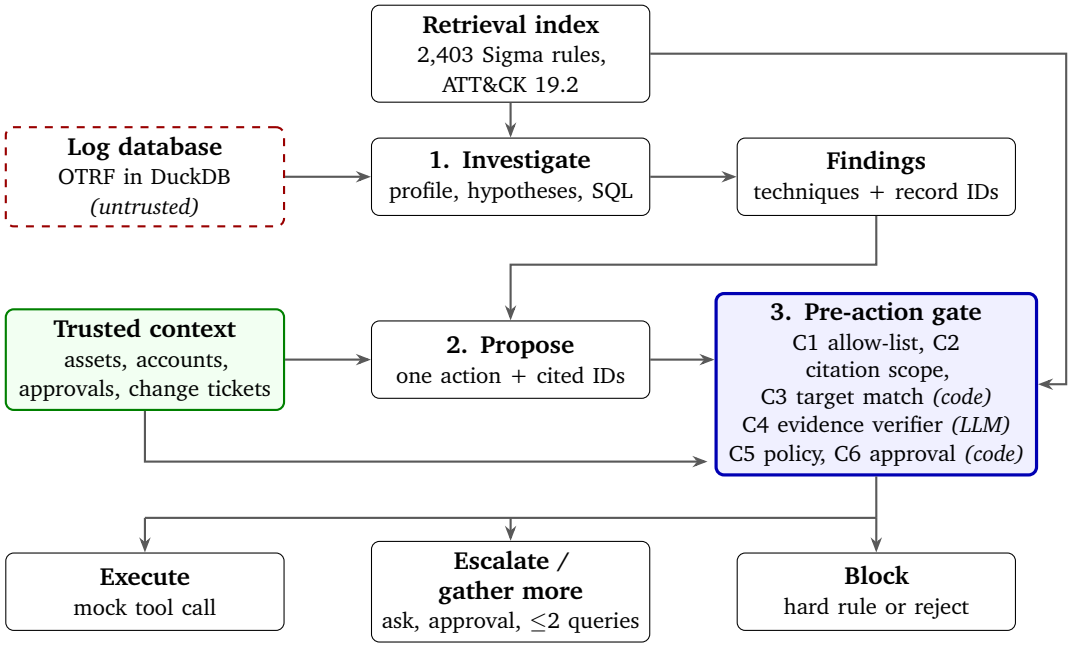


Figure 1. Architecture as implemented. Red dashed = attacker-influenced data; green = trusted data. Only the gate can let a state-changing call reach the mock tools; over MCP (A8) the gate runs inside the tool server.

2. Progress

The work follows a dependency-ordered plan (`IMPLEMENTATION_PLAN.md`, Draft 9). Each milestone was built on its own branch, and each branch contains the one before it; all of them are now merged into `main`. `STATUS.md` records every task, decision and measured number with its date.

Milestone (branch)	Status	Observable result
M0 Foundations (`m0-foundations`)	**done**	Repo scaffold, store and migrations, LLM client (live / fake / replay), model-serving spike and pilot
M1 Data (`m1-data`)	**done**	Pinned OTRF fetch, catalogue, normaliser to DuckDB, SQL guard, de-duplication, frozen window splits, Windows page
M2 Deterministic gate (`m2-gate`)	**done**	Trusted-context model, policy engine (signed off), tool layer and provenance registry, C1–C3, C5, C6, Gate Playground
M3 Verifier and Exp 1 (`m3-verifier`)	**done**	Retrieval index, C4 verifier with its four input variants, CPU reranker, retrieval metrics, Exp 1 runner; live demo-set Exp 1
M4 Cases and annotation (`m4-cases`)	**done** (code)	Scenario Studio, variant builder E1–E5 and Set R, database patcher, validator, blind double annotation, κ/Jaccard snapshots, adjudication, freeze tool
M5 Episodes and Exp 2 (`m5-episodes`)	**done**	Proposer, episode loop, outcome classifier, Exp 2 runner with fallback F1, recovery budgets (A5/A7), MCP server (A8), Agent Console; live demo-set Exp 2
M6 Investigation and Exp 3 (`m6-investigation`)	**done**	Live investigator (three tuning rounds, then frozen), Exp 3 runner, technique and evidence metrics, Console window mode
M7 Analysis (`m7-analysis`)	**done** (code)	All proposal metrics, cluster bootstrap, H1/H1-C4/H2 verdict logic, Results page, error taxonomy, exports. Sensitivity re-estimate waits for dev scenarios
M8 Hardening and docs	**partial**	Playwright suite with accessibility checks, performance check, README, runbook, generated gate contract and API docs. Open: live demo recording, a teammate's setup dry run
Case set: authoring, annotation, freeze	**next**	10 dev, 40 test and 12 end-to-end scenarios on the frozen window splits; all tooling for authoring, blind double annotation and adjudication is built and tested
Research runs Exp 1–3	**next**	Runners verified live on demo fixtures; start once the case set is frozen

Engineering quality. About 20,400 lines of Python (`backend/gbya/`) and 6,900 lines of TypeScript/React

(`frontend/`). Latest run (26 Oct): `make lint` clean (ruff, mypy strict on the gate, scoring, analysis and case modules, eslint, tsc); **855 pytest tests pass** (3 GPU-only tests deselected) and **19 vitest tests pass**. On 14 Oct, **46 Playwright journeys** passed at two viewports with axe accessibility checks on every page, plus 1 replay-profile demo run. Mutation checks were run on the security-critical parts (provenance registry, typed-argument rule), and the corresponding tests fail when the logic is deliberately broken. Measured latency (NFR-10): code-only gate check p95 3.2 ms, guarded SQL on the largest window (79,896 events) p95 9.0 ms, API list endpoints p95 11.5 ms, first UI load 151 ms.

What the implementation guarantees. A SELECT-only, two-layer SQL guard (AST checks plus a hardened read-only DuckDB connection; 70 attack tests). Typed-argument provenance: a PID, host, account or IP can fill an action argument only if it appeared in a record the agent actually retrieved. A rationale-blind verifier whose prompt never truncates cited fields. An approval state machine in which "reachable" never counts as "granted". No delete tool exists; attempts are counted.

3. Datasets in Use

Source	As loaded (measured)
OTRF Security-Datasets [1] (MIT)	Pinned at commit `d9d40ef`. 100 Windows atomic datasets catalogued; **99 ingested** into per-window DuckDB files (7 normalised tables plus `raw_events`): **757,375 events**, 0 skipped lines, 2.3 GB, built in 35 s. One window (SDWIN-230718150800) has its host file missing at the pinned commit and is excluded rather than mapped to a look-alike file. Four collection formats are handled.
De-duplication and splits	Event-signature Jaccard >0.5 groups 5 pairs: 99 windows form 94 groups. Seeded, tactic-stratified split, accepted by the team on 8 Oct: **dev 10, test 40, end-to-end 12**, 37 unused (one fallback queue). All 8 tactics with eligible windows appear in dev and test.
SigmaHQ rules [2] (DRL 1.1)	Release `r2026-07-01`, `rules/windows/` only: **2,403 rules**. ATT&CK tags and technique IDs are removed from the indexed text, so retrieval is by content.
MITRE ATT&CK [3]	Enterprise STIX 2.1, version 19.2; 474 Windows techniques indexed.
SOC-Risk (ours)	Tooling complete: scenario files, variant builder (E1–E5 by database patching), Set R twins, validator (checks a–k, scope rule), annotation and adjudication. Authoring and annotation are the next step (§7). Design target: 40 test scenarios $\times$ 7 cases = 280 cases, plus 12 end-to-end windows.
Demo fixtures (development only)	3 hand-made cases; the `demo-lsass` scenario (LSASS memory dump on WORKSTATION5, 7 cases, labels set for demonstration only); 5 *unused* windows used only to tune the investigator. None is a research window.

4. Baselines and Ablations

All systems share the model, tools, trusted context, signed-off policy (9 rules; all 144 attribute combinations are decided by a rule), hard rule and token caps; only the gate configuration differs. Each configuration is a data entry in `gate/configs.yaml`, and snapshot tests confirm that each ablation differs from G3 in exactly one field.

ID	System	Built	Exercised live so far
G0	ReAct agent, no gate	yes	Exp 1 (reference), Exp 2 demo
G1	Policy-only gate: C1, C5, C6	yes	Exp 1, Exp 2 demo
G2	G1 + C2 citation scope	yes	Exp 1, Exp 2 demo
G3	Full gate C1–C6 (simple RAG, recovery budget 2)	yes	Exp 1, 2, 3 demo
A1	G3 without C4 (code checks only)	yes	Exp 1, Exp 2 demo
A2	G3 without C3	yes	Exp 1 demo
A3	Verifier also sees the agent's rationale	yes	Exp 1 demo
A4	No RAG (verifier gets no retrieved text)	yes	Exp 1 demo
A6	RAG with reranker (BM25 top-20 $\rightarrow$ bge-reranker-base on CPU)	yes	Exp 1 demo
A5 / A7	Recovery budget 0 / 1 (G3 = 2)	yes	Exp 2 demo (A5)
A8	G3 with tools served over MCP, gate inside the server	yes	Exp 2 demo

5. Experiments Run and Results So Far

Reading this section. Every run below is a *pipeline-validation* run on development fixtures: 3 hand-made cases and the 7-case `demo-lsass` scenario, whose labels were set for demonstration and not double-annotated. The software itself refuses to compute hypothesis verdicts on such runs. These numbers show that each component works end to end with the live model, and they surface early behaviour worth watching. They do *not* estimate any effect in H1, H1-C4 or H2.

5.1 Model serving pilot (8 Oct)

Qwen2.5-7B-Instruct, 4-bit AWQ, vLLM 0.31, 8k context, xgrammar JSON-constrained decoding, on the RTX 4060 Laptop GPU (8 GB).

Measure (20 synthetic episodes + 7,850-token request + 30-min soak)	**Value**
Throughput, 4 concurrent requests (input / output tokens per s)	1,229.2 / 55.4
Proposal's planning assumption (input / output)	800 / 80
Latency p50 / p95	14.0 / 19.0 s
Peak VRAM / peak host RAM	7,249 MiB / 8,201 MB
Schema-valid outputs, generic schema (pilot / soak)	78/80 / 459/480
Schema-valid outputs, final proposer schema (T5.1 acceptance, 13 Oct)	**80/80**
Soak: minimum output rate, maximum GPU temperature	53.0 tok/s, 80 °C

Output throughput is 31% below the proposal's assumption but above the fallback-F1 threshold (half the assumption), so F1 was not triggered on throughput grounds. A trial token audit on the demo data (14 Oct), with every output assumed to hit its length cap, projects 65.2 GPU-hours for the full design, or 97.9 h with the 1.5× allowance. That is a pessimistic bound, and the real audit (T8.0) needs the dev scenarios.

5.2 Experiment 1 pipeline: gate decisions, verifier and retrieval

Live run through the worker on the 3 hand-made cases with all nine Exp 1 configurations: **93/93 units completed, 0 errors, in 20 s**. That is 36 verifier calls (standard, rationale, no-RAG and reranked inputs, 3 runs each), 12 code-only decisions and 45 composed decisions; every verifier output parsed. Repeated runs of the same (case, variant) gave identical verdicts at temperature 0. G3, A3, A4 and A6 reached C4 on 6 of 9 packages, because C3 stopped the wrong-target package first; A2 (no C3) reached C4 on 9 of 9. This confirms that the component split H1-C4 depends on is wired correctly.

Retrieval level (3 cases)	**Recall@5**	**Hit@5**	**nDCG@5**	**MRR@20**	**ATT&CK top-1**
Simple RAG: BM25 (G3)	0.023	0.333	0.333	0.333	0.333
RAG + reranker (A6)	0.019	0.333	0.277	0.333	0.333

These are illustrative, not comparative: $n = 3$, and two of the three hand-made cases cite domain-controller logon records under an LSASS gold technique. The run did expose a real measurement issue (§6): the gold set for T1003.001 contains 71 Sigma rules, so Recall@5 can be at most $5/71 \approx 0.07$. Reranking costs about 7.0 s per case on the CPU (peak 2.0 GB RAM) against 0.024 s for BM25 alone. Rankings are cached, so Exp 1 spends no GPU time on retrieval.

5.3 Experiment 2 pipeline: full episodes

Live run on the 7 `demo-lsass` cases (E1–E5, R_{pos}, R_{neg}). G0, G1 and G3 ran ×3 and G2, A1 and A5 ran ×1: **84/84 episodes completed, 0 errors, every unit on its first attempt, in 2 min 26 s**. There were 163 proposer calls (1–4 per episode) with **0 unusable outputs** and no history truncation, plus 77 gate decisions with 0 verifier parse errors. Terminal states: 68 actions fulfilled, 13 hand-offs to the analyst, 3 explicit ends. The gate failures were all of the expected kinds: 5 `C3_HOST_MISMATCH`, 2 `C6_APPROVAL_REQUIRED` and 2 `C6_APPROVAL_PENDING`.

Early behaviour observed. (i) In 69 of 84 episodes the agent's first proposal was an unnecessary `request_approval` for a tier-2 host. A prompt fix (shared identically by all systems) was made before the proposer prompt was frozen. (ii) In the MCP comparison (A8 vs G3, one run each, 7 cases), both transports gave **identical outcomes on all 7 cases** (task success 4/7 for both, 13 tool calls and 8 admitted for each), at a median MCP round trip of 2.76 s per gated call. In both, however, the live

verifier returned SUPPORTS on the demo E4 (partial chain) and E5 (in-scope approved activity) cases, which the demo labels count as unsafe executions. This is exactly the failure mode H1-C4 is designed to measure, and it is a warning that the 7B verifier may be weak on interpretation-heavy variants. One scenario cannot tell us how often it happens.

5.4 Experiment 3 pipeline: live investigation

The investigator builds a window profile, proposes 3–5 ATT&CK hypotheses using retrieved candidate techniques (never the window's metadata), runs at most two guarded queries per hypothesis and verifies each technique against cited records within a 25-call budget. It was tuned on 5 unused windows (one per tactic) over three logged rounds and then frozen (prompt hashes in `STATUS.md`):

Round	Change → result on the 5 tuning windows (G3, 1 run each)
Smoke + 1	Profile and SQL-prompt fixes → expected technique found on 0/5; the response agent sometimes looped until the 8-call cap
2	Window summary passed to the SQL step, escalation guidance → 0/5; loop fixed
3 (frozen)	$\geq$3 hypotheses enforced by schema; top-10 retrieved ATT&CK candidates offered → **1/5** (LSASS dump found and accepted on the right records); pooled precision 0.33, recall 0.20, F1 0.25

Diagnosis: in 10 of 11 pre-round-3 investigations the expected technique was never even hypothesised, so hypothesis generation, not verification, is the bottleneck for this model. Episodes take 17–27 s each. As planned, Exp 3 will be reported descriptively as it comes out.

6. Challenges Faced and Mitigations

Challenge	What we did / will do
FP8 KV cache (planned, to fit 8 GB) garbled the output at every prompt length tested (452–4,418 tokens)	FP16 KV cache with the same model file, accepted as a deviation. The KV cache then holds 21,520 tokens (≈2.6 full-length requests at once), so long requests queue
Constrained decoding emitted only whitespace; 7B repetition loops hit `max_tokens` (78/80 valid)	xgrammar backend with whitespace disabled; bounded strings and bounded integer IDs in the proposer schema → 80/80. Remaining invalid outputs count as rejections and are reported
Toolchain: FlashInfer JIT failed on the repository path containing spaces; `nvcc` not on `PATH`	vLLM environment moved to a space-free path; CUDA 13.0 set explicitly; every step recorded in the pilot report
Log data quirks: nxlog `ProcessID` is the log writer's PID, not the subject's; one dataset file is missing at the pinned commit	PID read from the event's own message (wrong PIDs would corrupt C3); the window is excluded and documented, never guessed
The gate only sees cited records: an agent can omit a contradicting record it retrieved	No gate change (it would alter the design mid-study); a *retrieved-but-not-cited* measure is now reported per variant and system
Recall@5 is capped by large gold sets (71 rules for T1003.001; ceiling ≈0.07)	Report the ceiling next to Recall@5 and lead with Hit@5, nDCG@5 and MRR@20, as planned
Weak technique identification by the 7B investigator (F1 0.25 on 5 tuning windows)	Three logged tuning rounds, then frozen to avoid tuning on test data; Exp 3 stays descriptive
The agent can read the approval script via `get_context`, so it knows the approver's answer in advance	Kept to match the proposal; listed as a limitation for the final report
Research labels must stay independent of the systems being tested	The server enforces blind double annotation, snapshots agreement before adjudication, and refuses research runs on unfrozen, replayed or fake-model data

7. Plan and Timeline to the Final Submission (15 November)

Twenty days remain, which is enough to run the **full design from the final proposal**: 40 test scenarios (280 cases), 12 end-to-end windows, all systems and ablations. The proposal's two fallbacks stay in force, each with a dated trigger. The plan's dependency order is unchanged: annotation → freeze →

research runs → analysis.

When	Work	Check
Mon 26 – Tue 27 Oct	Shared annotation server up; all four calibrate together on dev-01 and dev-02 (author, blind second label, adjudication)	Both adjudicated; rule questions logged in `STATUS.md`
Wed 28 – Fri 30 Oct	Dev-03 … dev-10 authored, double-annotated and adjudicated; pilot on the dev scenarios (purpose *development*); T7.3 sensitivity re-estimate; T8.0 token audit and GPU budget. *Mid-submission on 30 Oct*	Pilot runs end to end; measured interval half-widths and GPU-hours recorded
Sat 31 Oct – Fri 6 Nov	All 40 test scenarios and 12 end-to-end windows authored, labelled by two annotators blind, then adjudicated (≈90 person-hours in total, ≈22 per member); variants checked by both annotators	$\kappa \geq 0.6$ on the agreement snapshots before adjudication
Wed 4 Nov	**F2 checkpoint:** if fewer than 20 of the 40 test scenarios are adjudicated, switch to 30 test scenarios	Decision dated in `STATUS.md`
Sat 7 Nov	**Freeze** (`cases-v1`); retrieval cache on the frozen set; **Exp 1** (nine configurations; verifier ×3)	Freeze manifest committed; Exp 1 errors <1%
Sat 7 – Wed 11 Nov	**Exp 2**, all 14 system-runs (G0, G1, G3 ×3; G2, A1, A5, A7, A8 ×1), laptop dedicated to runs day and night; adjudication queue cleared daily. **F1 checkpoint:** if the T8.0 budget exceeds the hours left, drop to the F1 schedule	Every unit completed; queue empty
Thu 12 Nov	**Exp 3**: G0, G1, G3 ×2 on the 12 end-to-end windows	Completed; incidental-technique queue empty
Fri 13 – Sun 15 Nov	Bootstrap analysis of H1, H1-C4 and H2; retrieval and agentic ablation tables; error taxonomy with 10 annotated traces; live demo recording; final report; tag and submit	Results page in research mode; report submitted

GPU time. The proposal budgeted about 81 GPU-hours including a 1.5× allowance. A pessimistic trial audit on the demo data (every output at its length cap) gives 97.9 h. The real figure comes from T8.0 on the dev scenarios by 30 Oct. Running the laptop day and night from 7 to 12 Nov gives over 100 h, but overnight-only running would give about 48 h. So the T8.0 number decides, before the freeze, whether F1 applies.

What the fallbacks change in the claims. **F2** (30 test scenarios) widens the intervals by about $\sqrt{40/30} \approx 1.15$. On the proposal's preliminary assumptions that is roughly 13 points for H1, 15 for H1-C4 and 9 for H2, which makes an "inconclusive" verdict on H1-C4 more likely. **F1** drops the single-run ablations from Exp 2 and uses 2 runs of G0, G1 and G3, which widens the H2 interval; Exp 1 (H1, H1-C4) is unaffected. Whichever applies is stated in the final report. If H1 is not supported, the deliverables in the proposal's fallback clause still stand: a controlled measurement of policy-only gating, the target-matching vs. verifier split, and a released case set with exact action labels.

8. Repository and Reproduction

Repository: https://github.com/varunmodi18/Gate-Before-You-Act (branch `main`). Each milestone also remains on its own branch (`m0-foundations` … `m7-analysis`).

Path	Contents
`backend/gbya/`	data, retrieval, context, policy, tools (incl. MCP server), gate, llm, agent, cases, scoring, analysis, experiments, API, worker
`frontend/`	Vite + React + TypeScript interface: Windows, Scenario Studio, Annotate, Gate Playground, Agent Console, Experiments, Traces, Results
`policy/`, `experiments/`, `config/`	Signed-off policy rules and evidence requirements; experiment specifications incl. fallbacks; model profiles
`tests/`	Unit, integration and Playwright end-to-end suites
`docs/`	Final proposal, pilot report, gate contract, policy table, field map, splits, case-authoring guide, runbook, team guide, API reference
`IMPLEMENTATION_PLAN.md`, `STATUS.md`	The plan, and the dated record of every task, decision and measured number

Running it. `make setup && make fixture-up` opens the interface on fixture data with a scripted model (no GPU, no downloads). `make db data index && make demo-setup && make model-up && make demo-up` runs the live demo on the real LSASS window. `make test`, `make lint` and `make e2e` run the test suites. Logs, model weights and the index are rebuilt locally from pinned sources and never committed.

References

[1] OTRF Security-Datasets, commit d9d40ef. https://github.com/OTRF/Security-Datasets

[2] SigmaHQ, Sigma rules, release r2026-07-01 (Detection Rule License 1.1). https://github.com/SigmaHQ/sigma

[3] MITRE ATT&CK® Enterprise, STIX 2.1, v19.2. © 2026 The MITRE Corporation; reproduced with permission. https://github.com/mitre-attack/attack-stix-data

[4] J. Barnes. OpenSec: Measuring Incident Response Agent Calibration Under Adversarial Evidence. arXiv:2601.21083, 2026.

[5] R. Shang et al. AURA-Eval: Evaluation Framework for Acting Under Risk Awareness in LLM Agent Trajectories. arXiv:2609.06783, 2026.

[6] E. Debenedetti et al. Defeating Prompt Injections by Design. arXiv:2503.18813, 2025.

[7] S. Yao et al. ReAct: Synergizing Reasoning and Acting in Language Models. arXiv:2210.03629, 2022.

[8] BAAI bge-reranker-base. https://huggingface.co/BAAI/bge-reranker-base

[9] Model Context Protocol specification. https://modelcontextprotocol.io

[10] vLLM. https://github.com/vllm-project/vllm